Rapport d’Audit ISO 27001 - TechSecure Solutions

Equipe:

Sam LEVY,

Alberick Mahoussi,

Lucas POIGNARD,

Ahmed ELABAIDI,

Jibril MAHROUF,

Idriss TABERKANE,

Theo PAVLOVIC,

Romain GREGOIRE

Sommaire

1. Présentation du contexte et périmètre
2. Préparation de l'audit côté audité
3. Analyse de conformité ISO 27001
4. Point de vue auditeur
5. Plan d'actions corrective
6. Conclusion

1. Présentation du contexte et périmètre

1.1 Présentation de l'entreprise

TechSecure Solutions est une PME de 85 collaborateurs spécialisée dans l'édition de logiciels pour le secteur bancaire. En raison de la nature critique des données traitées (données bancaires et personnelles), la sécurité de l'information constitue un enjeu stratégique majeur pour l'organisation.

1.2 Pourquoi cette certification ?

La certification ISO 27001 est devenue un prérequis contractuel pour le renouvellement des marchés avec les clients grands comptes, notamment la Banque Régionale de l'Ouest. L'obtention de cette certification conditionne le maintien de 30% du chiffre d'affaires annuel.

1.3 Périmètre de l'audit

Le périmètre du SMSI est défini comme suit :

A - Inclus :

- Datacenter de Lyon
- L'équipe développement
- L'équipe support/exploitation
- L’infra IT interne
- Les process de développement, déploiement et maintenance
- La gestion des accès aux environnements clients

B- Exclus :

- Le site de Nantes
- Les applications des clients
- L’activité calculateurs embarqués

1.4 Parties prenantes

I- En interne nous avons :

- Le DG qui sponsorise le projet
- Le RSSI qui pilote tout le SMSI
- Le DSI pour la partie technique
- Les RH (habilitations, sensibilisation)

- Les équipes techniques

II- En externe nous avons :

- Les clients bancaires

2- Préparation de l'audit côté audité

2-1 Organisation

- **Documentation** : Adoption d'une approche proactive en centralisant les preuves via un outils GRC (Tenacy). Chaque responsable de mesure doit déposer ses preuves au fil de l'eau. Les rapports de sauvegarde sont archivés automatiquement chaque semaine
- **Coordination** : Désignation de pilotes de processus par le RSSI et mise en place d'une revue documentaire mensuelle.
- **Communication :** Sensibilisation du personnel aux enjeux de l'audit pour garantir la transparence et l'impartialité lors des entretiens

2-2 Documents Mise à disposition

Mise en place d'un pack audit :

Document	Version	Responsable
PSSI	v3.2	RSSI
SoA (Déclaration d'applicabilité)	v2.1	RSSI
Analyse de risques EBIOSRM	V1.4	RSSI
Procédure gestion des accès	V2.0	DSI
Procédure de sauvegarde	V1.8	Administrateur système
PCA/PRA	V1.2	DSI
Registre des incidents	Mise à jour continue	Support
CR de revue de direction	Trimestriels	Direction

2-3 Sensibilisation et préparation des équipes

Afin d'optimiser la posture de l'entité durant l'audit, une session de sensibilisation a été organisée pour l'ensemble des collaborateurs concernés. Les directives suivantes ont été instaurées :

- **Transparence opérationnelle** : Signaler toute anomalie ou difficulté identifiée. L'intégrité du processus d'audit repose sur une collaboration franche, les écarts étant inévitables.
- **Objectivité factuelle :** Les réponses lors des entretiens doivent se limiter à des faits vérifiables, en évitant toute justification subjective ou émotionnelle
- **Culture de la preuve :** Conformément au principe « ce qui n'est pas documenté n'existe pas », chaque affirmation doit être étayée par une preuve tangible (enregistrement, log, procédure).
- **Maîtrise du périmètre :** En cas d'incertitude sur une question technique, privilégier la vérification différée plutôt que la transmission d'informations erronées ou approximatives

2-4 Déroulement prévu

Conformément aux préconisations de la norme ISO 27006, la durée de l'audit initial a été estimée à 11 jours/homme pour un effectif de 85 employés.

Le planning opérationnel se décompose comme suit sur 3 jours :

Jour	Matin	Après-Midi
J1	Réunion d'ouverture et entretien avec la Direction Générale	Entretiens avec le RSSI et la DSI
J2	Audits des départements RH et Support Client	Inspection du Datacenter et entretiens avec l'Administration Système
J3	Revue documentaire finale et consolidation des constats	Réunion de clôture et restitution à chaud

3- Analyse de conformité ISO 27001

Nous avons sélectionné cinq mesures de **l'Annexe A**, jugées critiques au regard des enjeux contractuels avec le secteur bancaire

3-1 A.5.15 - Contrôle d'accès

Exigence : Mise en œuvre de règles de contrôle d'accès physique et logique rigoureuses.

Dispositif en place : La procédure PR-SEC-001 régit la gestion des identités. L'accès repose sur le principe du « moindre privilège » avec des comptes nominatifs.

Preuves de conformité :

1. Matrice des droits d'accès par profil
2. Exports de l'Active Directory
3. Rapports de revues semestrielles (dernière : octobre 2025)

Point de vigilance : Un défaut de traçabilité a été identifié concernant la revue de conformité de juin 2025 (absence de procès-verbal signé).

3-2 A.8.13 - Sauvegarde des informations

Exigence : Garantie de la disponibilité et de l'intégrité des données via des tests de restauration réguliers.

Dispositif en place : Politique POL-BACKUP-001 prévoyant des sauvegardes quotidiennes chiffrées (AES-256) et externalisées.

Preuves de conformité :

1. Rapports automatiques Veeam
2. Logs d'exécution des jobs de sauvegarde

Point de vigilance : Le cycle de test de restauration annuel n'est pas respecté (dernière occurrence constatée il y a 14 mois).

3-3 A.5.24 - Gestion des incidents de sécurité

Exigence : Capacité de réponse, de notification et d'analyse des incidents.

Dispositif en place : Processus PR-INC-001 utilisant l'outil GLPI pour la catégorisation et le suivi des tickets d'un niveau (P1 à P4) avec une remontée des tickets au RSSI selon le dégrée de gravité (P1 et P2).

Preuves de conformité :

1. Registre des incidents des 12 derniers mois
2. Rapports d'analyse post-incident

Point de vigilance : L'analyse de cause racine d'un incident de phishing majeur (Septembre 2025) s'est révélée incomplète

3-4 A.6.3 - Sensibilisation et formation

Exigence : Éducation continue du personnel aux menaces cyber.

Dispositif en place : Programme annuel incluant un e-learning obligatoire et des campagnes de phishing simulé.

Preuves de conformité :

1. Supports de formation
2. Feuilles d'émargement
3. Registres de complétion
4. Résultats des campagnes phishing

Point de vigilance : Déficit de participation (14% de non-complétion) et taux de vulnérabilité au phishing (18% de clics) supérieur aux objectifs cibles.

3-5 A.5.19 - Sécurité de l'information dans les relations fournisseurs

Exigence : Maîtrise des risques liés à la chaîne d'approvisionnement

Dispositif en place : Clause de sécurité standard et questionnaire d'évaluation annuelle pour les tiers critiques.

Preuves de conformité :

1. Modèle de clause contractuelle
2. Registre fournisseurs
3. Questionnaires complétés pour nos 5 fournisseurs critiques

Point de vigilance : Absence d'évaluation pour l'outil SaaS « CloudTicket », utilisé en production sans validation préalable du RSSI

4- Point de vue auditeur

En adoptant une méthodologie d'audit indépendante, les constats suivants ont été formalisés :

4-1 Non – Conformités

Non-Conformité	**Exigence**	**Constat Factuel**	**Preuve**	**Risque Associé**
NC-01	**A.8.13**	Défaut d'exécution des tests de restauration annuels.	Registre des tests (dernière entrée : 15/11/2024).	Incapacité à garantir le RTO en cas de sinistre majeur.
NC-02	**A.5.19**	Intégration d'un service SaaS (CloudTicket) sans revue de sécurité.	Contrat du 01/03/2025 dépourvu d'annexe sécurité.	Fuite potentielle de données bancaires chez un tiers non audité.
NC-03	**A.5.15**	Absence de formalisation de la revue des accès de juin 2025.	Défaut de preuve documentaire dans le dossier de preuve.	Maintien d'accès obsolètes pour des collaborateurs ayant quitté l'entité.

4-2 Observations

1. Le programme de sensibilisation (A.6.3) présente des indicateurs de performance en deçà des attentes (18% de clics phishing). Une revue de l'efficacité pédagogique est recommandée.
2. L'analyse post-incident (A.5.24) manque de profondeur. La recherche des causes profondes doit être systématique pour assurer la non-récurrence des événements.

4-3 Opportunités d'Amélioration

1. Automatisation du suivi de complétion des formations via un tableau de bord (Dashboard) en temps réel.
2. Intégration d'un jalon « Sécurité » obligatoire dans le processus d'achat (Procurement) pour prévenir le Shadow IT

5. Plan d'actions correctives

5.1 Traitement de la NC-01 (Tests de restauration)

- **Action :** Exécution immédiate d'un test de restauration sur l'environnement de préproduction et institutionnalisation d'un calendrier trimestriel.
- **Responsable :** Administrateur Systèmes.
- **Délai :** 15 jours.
- **Preuve de clôture :** Procès-verbal de restauration validé.

5.2 Traitement de la NC-02 (Sécurité Fournisseurs)

- **Action :** Évaluation rétroactive du fournisseur CloudTicket et négociation d'un avenant incluant les clauses de sécurité du groupe.
- **Responsable :** RSSI / Service Achats.
- **Délai :** 2 mois.
- **Preuve de clôture :** Questionnaire de sécurité complété et avenant signé.

5.3 Traitement de la NC-03 (Revue des accès)

- **Action :** Réalisation d'une revue de rattrapage et création d'un modèle standardisé de compte-rendu.
- **Responsable :** DSI.
- **Délai :** 3 semaines.
- **Preuve de clôture :** Nouveau PV de revue d'accès et mise à jour de la procédure PR-SEC-001.

6. Conclusion

6.1 Retours d'expérience

Cet audit réaliser, mets en exergue l'importance de la permanence des contrôles. La conformité ne doit pas être perçue comme un événement ponctuel, mais comme un processus continu de collecte de preuves. L'utilisation d'outils de GRC est apparue comme un facteur clé de succès pour structurer cette démarche.

6.2 Les limites à retenir

L'audit est une « photographie » à un instant T, soumise aux aléas de l'échantillonnage. Il est crucial de distinguer la **conformité documentaire** (l'existence de règles) de l'**efficacité opérationnelle** (la réalité des pratiques). Le facteur humain reste la variable la plus complexe à maîtriser lors des entretiens.

6.3 Les recommandations stratégiques pour TechSecure

Pour pérenniser son SMSI, TechSecure doit :

1. **Systématiser la traçabilité :** Tout acte technique ou managérial doit générer un enregistrement.
2. **Décloisonner la cybersécurité :** Intégrer la conformité dès la phase d'achat et dans les processus métiers.
3. **Adopter le cycle PDCA :** Utiliser les non-conformités non pas comme des échecs, mais comme des leviers d'amélioration continue pour atteindre un niveau de maturité supérieur